Secure Network Design – D482

Athanase Ali

A. Two network security problems and two current infrastructure problems

Company A

Insufficient Endpoint Security: Company A faces challenges in ensuring comprehensive endpoint security for its global operations, particularly in protecting customer information related to financial products. Inadequate endpoint security measures may expose the company to the risk of data breaches and unauthorized access.

Legacy Authentication Systems: The financial industry demands robust authentication methods. Company A may be grappling with legacy authentication systems that could pose vulnerabilities and potentially compromise customer data security.

Outdated Network Infrastructure: The existing network infrastructure of Company A may be outdated, hindering the adoption of emerging technologies such as zero trust principles and cloud integration. This poses a challenge in achieving the scalability and redundancy required for a global financial company.

Limited Cloud Integration: While there is an interest in using the cloud for scalability and redundancy, Company A may currently lack a seamless integration of cloud-based technologies into its existing infrastructure. This limitation hampers the company's ability to fully leverage the benefits of cloud services.

Company B

Lack of Dedicated Cybersecurity Professionals: Company B's absence of a dedicated cybersecurity professional increases the risk of overlooking critical security measures. This gap may lead to vulnerabilities in the specialized software provided to medical providers, potentially exposing sensitive medical and financial data.

Third-Party Support Vulnerabilities: Relying on third-party support for infrastructure needs introduces potential security vulnerabilities. Company B may face challenges in ensuring that third-party services align with the financial and medical industry's stringent security standards, exposing the company to compliance risks.

Inadequate Data Encryption Practices: Given that Company B accepts credit cards as a payment option, ensuring robust data encryption practices is paramount. Inadequate encryption measures may expose credit card information to potential breaches, leading to severe financial and reputational repercussions.

Limited Scalability: The specialized software provided by Company B to medical providers may encounter scalability issues as the company grows. This limitation could affect the performance and responsiveness of the software, impacting the quality of service provided to medical clients.

B. Describe two existing vulnerabilities and explain their impact, risk, and likelihood

Company A

Open ports vulnerability: The presence of open ports 21-90 and 3389 poses a significant risk to Company A's network. These ports are commonly associated with FTP, remote desktop, and potentially other services. If left open, unauthorized access to sensitive data (confidentiality) and the potential for malicious activities (integrity) increase substantially. The risk is high as exploitation of these ports could lead to unauthorized access and potential data compromise. The likelihood is high as open ports are often targeted by automated scans and malicious actors.

All users use eight-character passwords vulnerability: The use of eight-character passwords increases the risk of unauthorized access, posing a threat to both confidentiality and integrity.

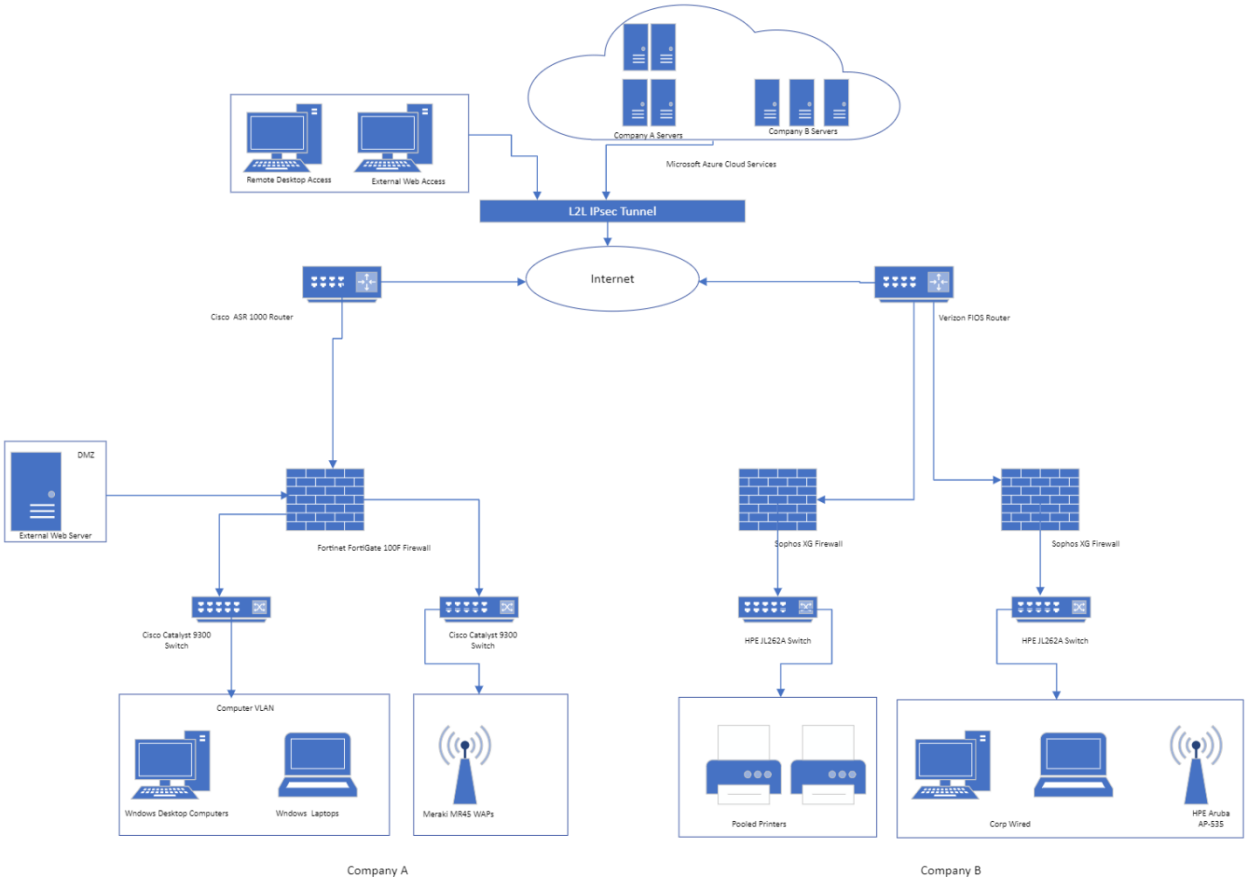
Short passwords are susceptible to brute-force attacks, potentially leading to compromised user accounts and unauthorized access to sensitive information. The risk is high as compromised accounts can result in data breaches and system manipulation. While the likelihood is moderate, it remains a significant concern, especially with automated password-cracking tools.

Company B

MFA not enforced across all user's vulnerability: The lack of Multi-Factor Authentication (MFA) for all users increases the risk of unauthorized access. Without MFA, compromised credentials could lead to unauthorized access, posing threats to confidentiality, and integrity, and potentially disrupting system availability. The risk is high as unauthorized access can result in data breaches and manipulation. The likelihood is high, given the prevalence of credential-based attacks and the importance of MFA in mitigating such risks.

PostgreSQL admin reachable from internet vulnerability: The exposure of a PostgreSQL admin interface to the internet poses a significant risk to the confidentiality and integrity of the database. Unauthorized access to the admin interface could lead to data manipulation or extraction. The risk is high due to the sensitivity of the data in a database, but the likelihood is low as direct internet exposure of admin interfaces is not common and requires specific misconfigurations.

C. Network topology diagram of the proposed merged network



D. OSI model and TCP/IP protocol stack from the merged network

Device	OSI Layer	TCP/IP Layer
Firewall	Layer 7 - Application	Application
Router	Layer 3 - Network	Internet
Servers	Layer 7 - Application	Application
Cabling	Layer 1 - Physical	Network Interface
Ipsec VPN	Layer 3 - Network	Internet
Laptops and Workstations	Layer 7 - Application	Application
Switches	Layer 2 - Data Link	Network Interface
Printers	Layer 7 - Application	Application
WAPs	Layer 2 - Data Link	Network Interface
Microsoft Azure	Layer 7 - Application	Application

E. Rationale for adding, deleting, and repurposing network components

Product	QTY	PRICE	TOTAL
Cisco Catalyst 9300 Series	4	$3,000	$12,000
Fortinet FortiGate 100F	1	$8,000	$8,000
Cisco ASR 1000 Series	1	$14,028	$14,028
Microsoft Azure Cloud	12	$526.14	$6,313.68
Windows Server 2019	7	$799.98	$5,600
Microsoft Windows 10 Pro	16	$199.99	$3,199.84
Total			$49,141
Budget			$50,000
Balance			$859

After carefully reviewing the list of networking components for both companies, some of the components reached their end-of-life. I upgraded the four Cisco 3750X switches to the Cisco Catalyst 9300 Series. I also purchased a new Fortinet FortiGate 100F NGFW and a border router Cisco ASR 1000Series for company A. All these network components made sense to purchase because they are the newest in class and the previous ones are not supported anymore by the manufacturer (no updates or patches) making them vulnerable to security breaches. It would be easy for an attacker to research their vulnerabilities and use them to access the network and steal information. Both companies were using old versions of Windows Server 2012 on-premises, Windows XP, and Windows 7. It made sense to buy new licenses for Windows 2019 Server and Windows 11 Pro to upgrade their operating system. It also made sense to purchase because old operating systems are not supported with patches and updates anymore by the manufacturer leaving them vulnerable. Other networking components such as the Meraki M28 access points, cable 5e, HPE JL262A switches, Verizon FIOS CR1000A, Sophos XG, and the HPE AP535 access points are still available and supported by the manufacturer. Due to financial constraints, it made sense to retain them as they can still receive security patches and software updates.

F. Discuss two network design principles implemented into the merged topology

I implemented network segmentation in the merged diagram, I accomplished that with the new Fortinet FortiGate 100F NGFW and new Cisco Catalyst 9300 Series switches. The FortiGate 100F delivers secure networking that is broad, deep, and automated. It secures the network end to end with advanced edge protection. Its network segmentation and secure SD-WAN capabilities reduce the complexity and risk in hybrid IT networks. The Cisco switches provide a simplified segmentation and micro-segmentation, with predictable performance and scalability.

Another network design principle that I implemented is Zero Trust. The Fortinet FortiGate 100F NGFW has universal built-in ZTNA that automatically controls, verifies, and facilitates user access to application, while reducing lateral threats by providing access only to validated users. Its ultra-fast threat protection and SSL inspection provides security at the edge without impacting performance. The additional Cisco ASR 1000 Series router allows for unified access security and multi-factor authentication. Based on the zero-trust security model, it allows SD-WAN secure connections to all applications based on the trust worthiness of users and devices.

G. Discuss two relevant regulatory compliances and why they are relevant

Payment Card Industry Data Security Standard (PCI DSS)

This regulation is relevant because it is crucial for the newly merged company, they both accept credit card payments. Compliance is then essential to assure that cardholder data is protected, to prevent fraud, and maintain the trust with the customer base. Segregation of Payment Processing: The network topology diagram delineates payment processing resources, specifically those associated with Company B, into distinct segments labeled as "Company B Resources." This demarcation restricts access to payment card data exclusively to authorized personnel, aligning seamlessly with PCI DSS's mandate for stringent access control.

Encryption: The diagram integrates robust encryption mechanisms, exemplified by TLS (Transport Layer Security), across multiple layers, with particular emphasis on the Zero Trust Zone and cloud-based services. This encryption fortifies the security of sensitive payment data throughout transmission and storage, fulfilling a pivotal PCI DSS stipulation.

Monitoring and Logging: The Zero Trust Zone incorporates ongoing monitoring and logging of network traffic and access attempts. This continuous oversight serves to promptly identify and respond to any anomalous activities associated with payment card data, effectively addressing PCI DSS's imperative for vigilant monitoring and alerting.

Access Controls: Within the confines of the Zero Trust Zone, rigorous access controls are meticulously enforced in adherence to the principle of least privilege. Solely authorized personnel possess the capability to access payment card data, adhering meticulously to PCI DSS's directive for stringent access restriction.

Health Insurance Portability and Accountability Act (HIPAA)

This regulation is relevant because Company B provides specialized software to medical providers. Since they manage protected health information (PHI), they must comply with HIPAA regulations to safeguard patient data. Segmentation and Isolation: The network topology diagram establishes a dedicated segment labeled "Company B Resources" to segregate and isolate Company B's assets. This intentional separation serves to maintain the distinctiveness of Protected Health Information (PHI), minimizing the likelihood of unauthorized access and breaches in accordance with HIPAA regulations.

Encryption and Secure Transmission: Robust encryption measures, particularly within the Zero Trust Zone and cloud-based services, are implemented to safeguard the confidentiality and integrity of PHI during data transmission. This initiative-taking approach aligns with the stipulations of HIPAA, ensuring the secure transfer of sensitive health information.

Access Controls: The Zero Trust Zone implements stringent access controls based on role-based authentication and authorization protocols. Access to PHI is limited to authorized personnel with legitimate roles, a practice that aligns seamlessly with HIPAA's stringent access control prerequisites.

Logging and Auditing: Continuous monitoring and logging within the Zero Trust Zone extend to auditing access to PHI. This comprehensive approach allows the company to track instances of access to patient data, thereby fulfilling HIPAA's requirement for thorough audit trails.

By incorporating these measures into the network topology diagram, the newly merged company underscores its dedication to safeguarding sensitive data, whether it be patient health information subject to HIPAA or payment card data governed by PCI DSS. This commitment not only

ensures legal compliance but also instills confidence among customers and partners in the company's data protection practices.

H. Discuss threats that would occur during or after the merger

Insider Threats

Potential Network Security Risks: Inherent security risks involve the prospect of malicious or negligent actions from internal sources, encompassing employees, contractors, or business partners, all of whom may possess access to sensitive data within the Zero Trust Zone.
These internal actors could intentionally disclose confidential information, compromise system integrity, or engage in illicit data exfiltration.
Potential Performance Impacts: Enforcing stringent access controls and monitoring mechanisms to detect internal threats could result in heightened network overhead and potential delays in legitimate access requests. Thorough monitoring and auditing for internal threats may generate a substantial volume of logs and events, potentially affecting both network and storage performance.
Management of Identified Security Risks:
User Behavior Analytics: Leverage user behavior analytics tools for continual monitoring, identifying any anomalous or suspicious activities among authorized users to promptly detect potential internal threats. Role-Based Access Control (RBAC): Deploy RBAC policies to ensure that employees only have access to resources essential for their roles, thereby mitigating the potential impact of internal threats. Insider Threat Training: Conduct training and awareness programs to educate employees on the nuances of internal threat risks, underscored by the importance of responsible data handling and the reporting of any suspicious activities.
Scalable Logging and Storage: Guarantee that the network infrastructure is equipped to oversee the escalated volume of logs stemming from internal threat monitoring, considering scalable storage solutions to accommodate this influx of data.

Advanced Persistent Threats (APTs)

Potential Network Security Risks: Advanced Persistent Threats (APTs) represent sophisticated and enduring cyber-attacks that may focus on infiltrating the consolidated organization's network with the intention of illicitly accessing, pilfering sensitive data, or disrupting operational functions. These threats possess the capability to potentially breach the confines of the Zero Trust Zone, exploiting vulnerabilities or employing social engineering tactics to compromise authorized accounts.
Potential Performance Impacts: The introduction of supplementary security measures to detect and counter APTs may induce latency in network traffic, potentially influencing network performance and responsiveness. The consistent monitoring and analysis necessary for APT detection may necessitate substantial network and computing resources, affecting the overall efficiency of the network.
Management of Identified Potential Security Risks: Deployment of Advanced Threat Detection: Integrate advanced threat detection tools, encompassing behavioral analytics, anomaly detection, and threat intelligence feeds, to promptly identify and respond to APTs in real-time.
Scheduled Security Assessments: Undertake periodic security assessments, including penetration testing and red team exercises, to uncover vulnerabilities and evaluate the organization's resilience against APTs. Employee Training and Awareness: Educate employees to recognize and thwart social engineering attempts while enforcing stringent access controls to diminish the risk of unauthorized APT access. Optimization of Network Performance: Continuously monitor and

optimize network performance to mitigate any introduced latency from security measures, thereby ensuring the seamless operation of the network.

I. Summary of recommendations for the implementation of the merged network

1. Cost-Benefit Analysis
   It is a method used to evaluate a project by comparing its losses and gains — a quantified and qualified list of pros and cons. CBA is a useful way to assess business projects because it reduces the evaluation complexity to a single price figure.

Considering the scenario and budget constraints, the execution of the envisioned consolidated network should give precedence to security, scalability, and compliance, all within a cost-effective framework. To encapsulate the key suggestions:

Cost-Benefit Evaluation for On-Premises and Cloud Infrastructure Solutions:

On-Premises Infrastructure:

Advantage: Leveraging existing on-premises infrastructure can yield immediate cost savings, especially suitable for hosting legacy applications and safeguarding sensitive data not immediately transferable to the cloud.

Expense: Ongoing costs for maintenance and upgrades can accrue. Dedicated resources and investments are required for robust security measures and compliance efforts.

Cloud-Based Infrastructure:

Advantage: Cloud services present scalability, redundancy, and robust security features. They can adeptly adjust to evolving demands, minimizing the need for upfront capital expenditure. Cloud providers often furnish compliance tools and share security responsibilities.

Expense: While cloud services hold the potential for cost-effectiveness, vigilant resource management is crucial to mitigate unforeseen expenses. Sustained operational costs can accumulate over time.

2. Justification for recommendations
   Executing the Proposed Secure Merged Network Design:
   The envisioned merged network design seamlessly integrates Zero Trust Architecture, segmentation, and isolation, adhering to contemporary security best practices.
   It caters specifically to the merged organization's requirements, encompassing secure payment processing, safeguarding sensitive health data, and ensuring compliance with both PCI DSS and HIPAA.
   Strategically leveraging cloud-based services, the design offers scalability, redundancy, and robust security capabilities, harmonizing with the organization's objectives and fiscal limitations.
   Integration of on-premises infrastructure, where necessary, optimizes the utilization of existing resources while facilitating a gradual transition to the cloud.
   Key elements of the design include continuous monitoring and comprehensive employee training to effectively manage emerging threats.

   Overall Rationale:
   The recommended approach achieves equilibrium among security, scalability, and compliance within budgetary constraints. It harnesses cloud services to enhance agility while safeguarding the integrity of sensitive data. The design aligns meticulously with regulatory

prerequisites (PCI DSS and HIPAA) and industry benchmarks. A focus on cost-effectiveness is maintained through meticulous resource allocation and scalability.

In summary, the execution of the proposed merged network design strikes a harmonious balance between security, regulatory adherence, scalability, and fiscal prudence. By judiciously employing cloud services and optimizing existing infrastructure, the merged organization stands poised to attain its objectives within the stipulated budget, all while upholding a steadfast commitment to network security and compliance.

J. Work Cited

(2023) *FortiGate 100F series data sheet*. Available at: https://www.fortinet.com/content/dam/fortinet/assets/data-sheets/fortigate-100f-series.pdf (Accessed: 20 December 2023).

Buy and download windows 11 pro: Microsoft (2023) *Microsoft Store*. Available at: https://www.microsoft.com/en-us/d/windows-11-pro/dg7gmgf0d8h4 (Accessed: 20 December 2023).

Chapple, M. (2021a) *TCP/IP Networking - Nmap Video tutorial: LinkedIn learning, formerly Lynda.com*, *LinkedIn*. Available at: https://www.linkedin.com/learning/security-testing-nmap-security-scanning-14221942/tcp-ip-networking?u=2045532 (Accessed: 20 December 2023).

Chapple, M. (2021b) *TCP/IP Networking - Nmap Video tutorial: LinkedIn learning, formerly Lynda.com*, *LinkedIn*. Available at: https://www.linkedin.com/learning/security-testing-nmap-security-scanning-14221942/tcp-ip-networking?autoplay=true&u=2045532 (Accessed: 20 December 2023).

CISCO ASR 1000 Series Aggregation Services Routers Data Sheet (2023) *Cisco*. Available at: https://www.cisco.com/c/en/us/products/collateral/routers/asr-1000-series-aggregation-services-routers/datasheet-c78-731632.html (Accessed: 20 December 2023).

CISCO ASR 1001 Router ASR 1000 Series Aggregation Services Router (2023) *Cisco ASR 1001 Router | SecureITStore.com*. Available at: https://www.secureitstore.com/ASR-1001.asp (Accessed: 20 December 2023).

Consolidate your security with Sophos Firewall (2023) *SOPHOS*. Available at: https://www.sophos.com/en-us/products/next-gen-firewall?utm_source=google&utm_medium=cpc&utm_campaign=mg-2023-na-en-demg-gog-bra-convr-net-search-phrase&utm_term=sophos+xgs&utm_content=na&cmp=7014w000001sPswAAE&gad_source=1&gclid=Cj0KCQiAm4WsBhCiARIsAEJIEzWlE-O58uEM-sWIKyavTjUJMRBNp6LGsj9JMwFWOPkuQ7AVsZwxVu8aAoWvEALw_wcB&gclsrc=aw.ds (Accessed: 20 December 2023).

Pricing - cloud services: Microsoft Azure (2023) *Pricing - Cloud Services | Microsoft Azure*. Available at: https://azure.microsoft.com/en-us/pricing/details/cloud-services/ (Accessed: 20 December 2023).

Winter, H. (2019) *The Business Analysis Handbook: Techniques and Questions to Deliver Better Business Outcomes*, *Percipio*. Available at: https://wgu.percipio.com/books/9c2a7a3b-4d92-45ad-a6ee-027a3cfb2a40#epubcfi(/6/50!/4/2[epubmain]/2[ch03lev1sec6]/2/2/1:0)183&site=eds-

live&scope=site&authtype=sso&custid=ns017578&ebv=EB&ppid=pp_185 (Accessed: 20 December 2023).

Todd Lammle. (2022). *CompTIA Network+ Study Guide: Exam N10-008: Vol. Fifth edition*. Sybex.

Michael Stewart, & Denise Kinsey. (2021). *Network Security, Firewalls, and VPNs: Vol. Third edition*. Jones & Bartlett Learning.

Cisco Catalyst 9300 Series Switches Data Sheet (2023) *Cisco*. Available at: https://www.cisco.com/c/en/us/products/collateral/switches/catalyst-9300-series-switches/nb-06-cat9300-ser-data-sheet-cte-en.html (Accessed: 20 December 2023).

Douglas Landoll. (2021). *The Security Risk Assessment Handbook: A Complete Guide for Performing Security Risk Assessments*. CRC Press.

Shackleton, T. (2023, August 10). *A cost-benefit analysis approach to cyber security*. Six Degrees. https://www.6dg.co.uk/blog/cost-benefit-approach-to-cyber-security/